

Enterprise Security Assessment (ESA)

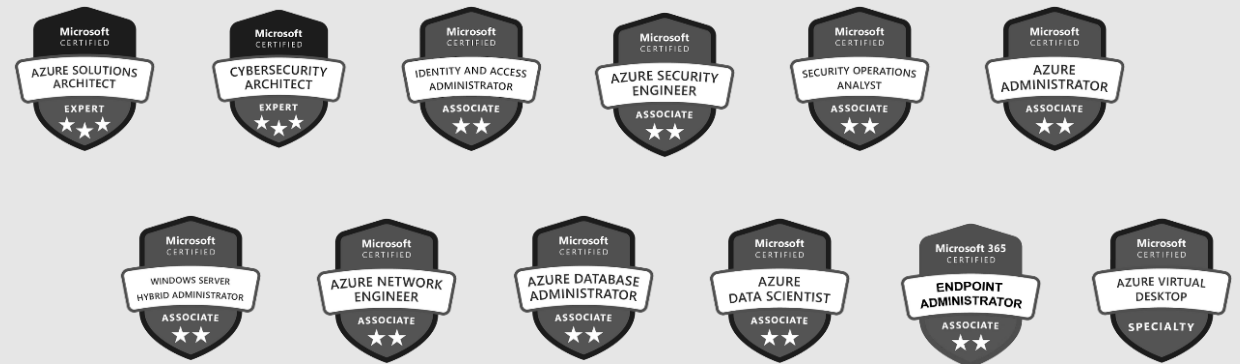
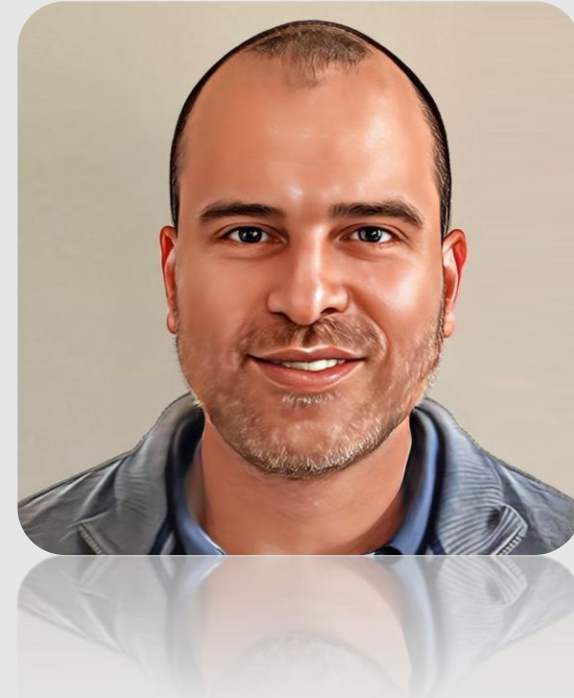
Scoping

Thomas Bründl



Thomas Bründl MSc. BSc.
Cloud Solution Architect (CSA) @ Microsoft
Sentinel, XDR

E-Mail: thomas.bruendl@microsoft.com
Blog: <https://it-infrastructure.solutions>
LinkedIn: <https://www.linkedin.com/in/thomas-bruendl>
Twitter: @TBrundl



Conditions and terms of use

© Microsoft Corporation. All rights reserved.

You may use these training materials solely for your personal internal reference and non-commercial purposes. You may not distribute, transmit, resell or otherwise make these training materials available to any other person or party without express permission from Microsoft Corporation. URL's or other internet web site references in the training materials may change without notice. Unless otherwise noted, any companies, organization, domain names, email addresses, people, place and events depicted in the training materials are for illustration only and are fictitious. No real association is intended or inferred. THESE TRAINING MATERIALS ARE PROVIDED "AS IS"; MICROSOFT MAKES NO WARRANTIES, EXPRESS OR IMPLIED IN THESE TRAINING MATERIALS.

Agenda



Introduction to Enterprise Security Assessment (ESA)



Objectives



Scope



Agenda and activities



Outcomes



Requirements and Next steps



Overview of Enterprise Security Assessment



What does this service help you with



The **Enterprise Security Assessment** engagement provides a comprehensive evaluation designed to identify and summarize security recommendations within a single-tenant enterprise environment.

Provides detailed visuals via a Power BI dashboard, highlighting areas needing attention and enabling repeated use.

Delivers actionable recommendations, ensuring continuous improvement of the customer's security posture.

Objectives

Enterprise Security Assessment

Security Landscape	• Provide you with an understanding of your security landscape.
Security Improvement	• Establish a plan to improve security.





Assessment Data

Assessment information is based on data from the following sources:

Microsoft Cloud Security Benchmark (MCSB)



The Microsoft Cloud Security Benchmark (MCSB) provides prescriptive best practices and recommendations to help improve the security of workloads, data, and services on Azure and multi-cloud environments. This benchmark focuses on cloud-centric control areas with input from a set of holistic Microsoft and industry security guidance.

Defender for Cloud – Secure Score Recommendations



The recommendations in Microsoft Defender for Cloud helps improve cloud security posture by aggregating security findings into a single score, allowing for a quick assessment of the current security situation. Recommendations are grouped into security controls, which are logical groups of related security recommendations reflecting vulnerable attack surfaces.

Microsoft Secure Score



Microsoft Secure Score provides a holistic measure of an organization's security posture across various Microsoft services, including Microsoft 365 and Azure, focusing on identity, data, devices, apps, and infrastructure (for example, Entra ID, Teams, Exchange Online, SharePoint Online, and more).

Microsoft Purview Compliance Manager



Microsoft Purview Compliance Manager improvement actions help organizations assess and manage their compliance posture across multicloud environments by providing recommended guidance aligned with data protection regulations and standards, with automated testing and continuous monitoring.

Engagement Approach and Agenda



Data Gathering

Customer will need to gather data by exporting four files and providing them to Microsoft.

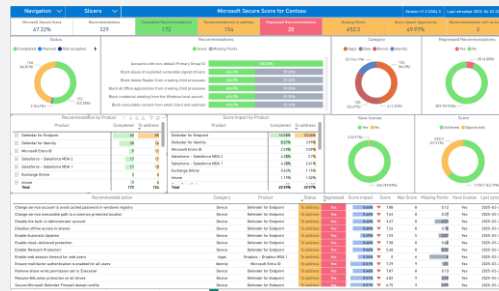
1. Defender for Cloud Secure Score recommendations for all subscriptions in scope.
2. Microsoft Cloud Security Benchmark recommendations for all subscriptions in scope.
3. Microsoft Secure Score export.
4. Microsoft Purview Compliance Manager Improvement Actions

Customer work



Data Integration in Power BI Dashboard

- Microsoft will review and analyze the data and integrate it into a Power BI dashboard for visualization and filtering.
- Microsoft will create a proposed roadmap to serve as a jumpstart implementation plan and develop an executive summary presentation highlighting the top findings.



Microsoft work



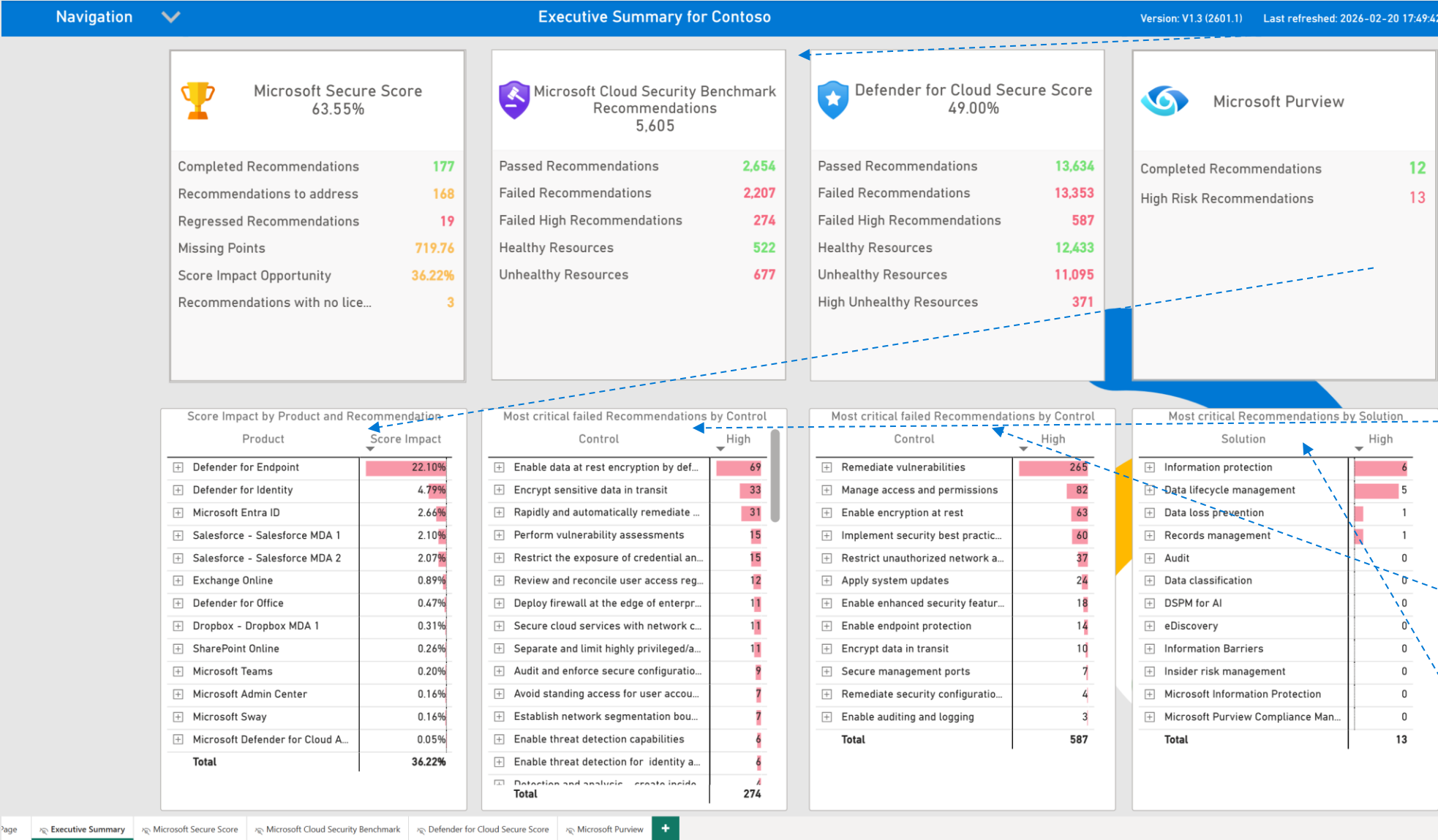
Presentation of Results

- Microsoft will present the assessment results and the proposed roadmap in a two-hour meeting and share the Power BI dashboard with the customer.

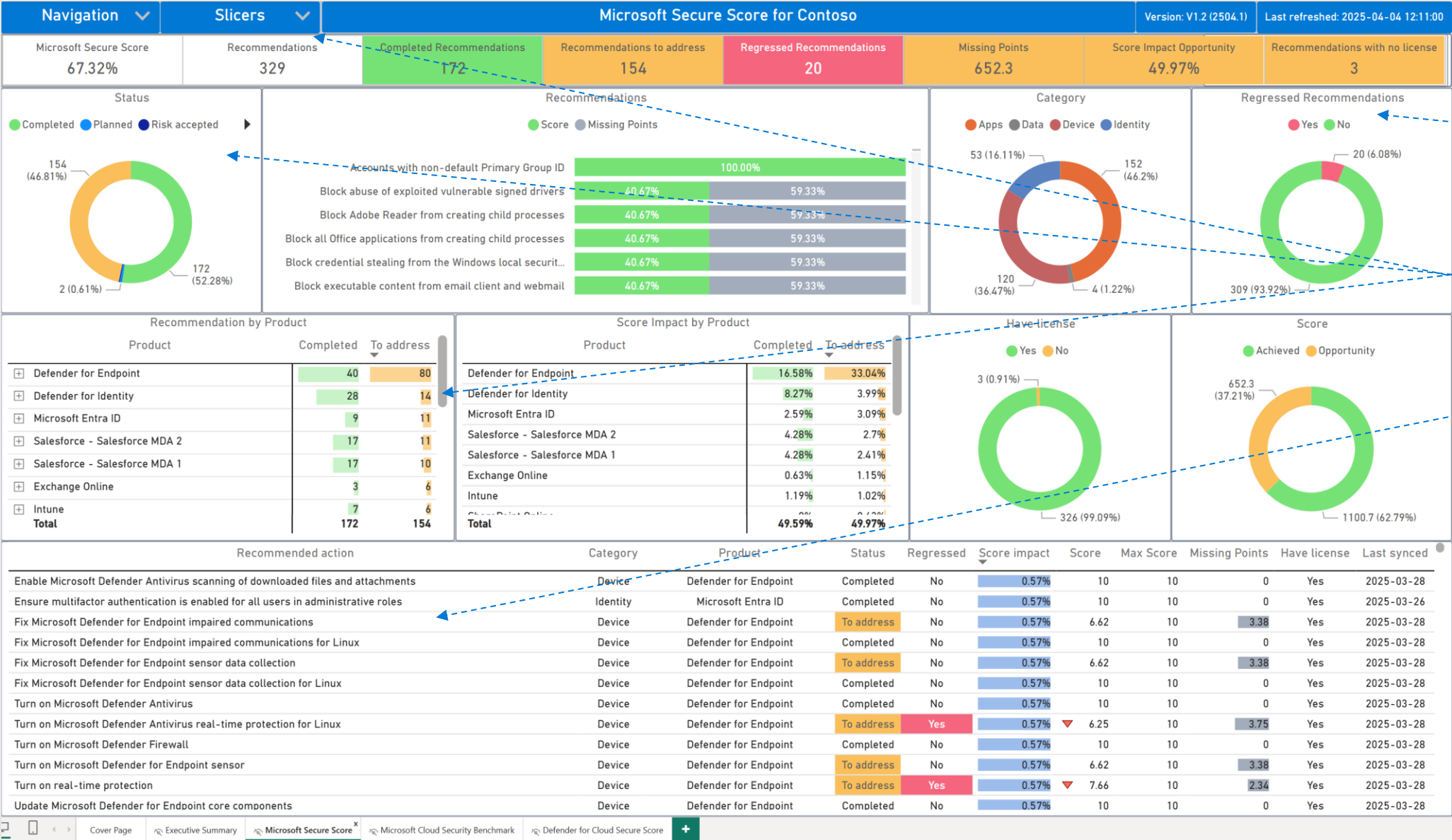


Teams Meeting

Power BI Dashboard – Executive Summary Example



Power BI Dashboard – Microsoft Secure Score Example



Regressed resources

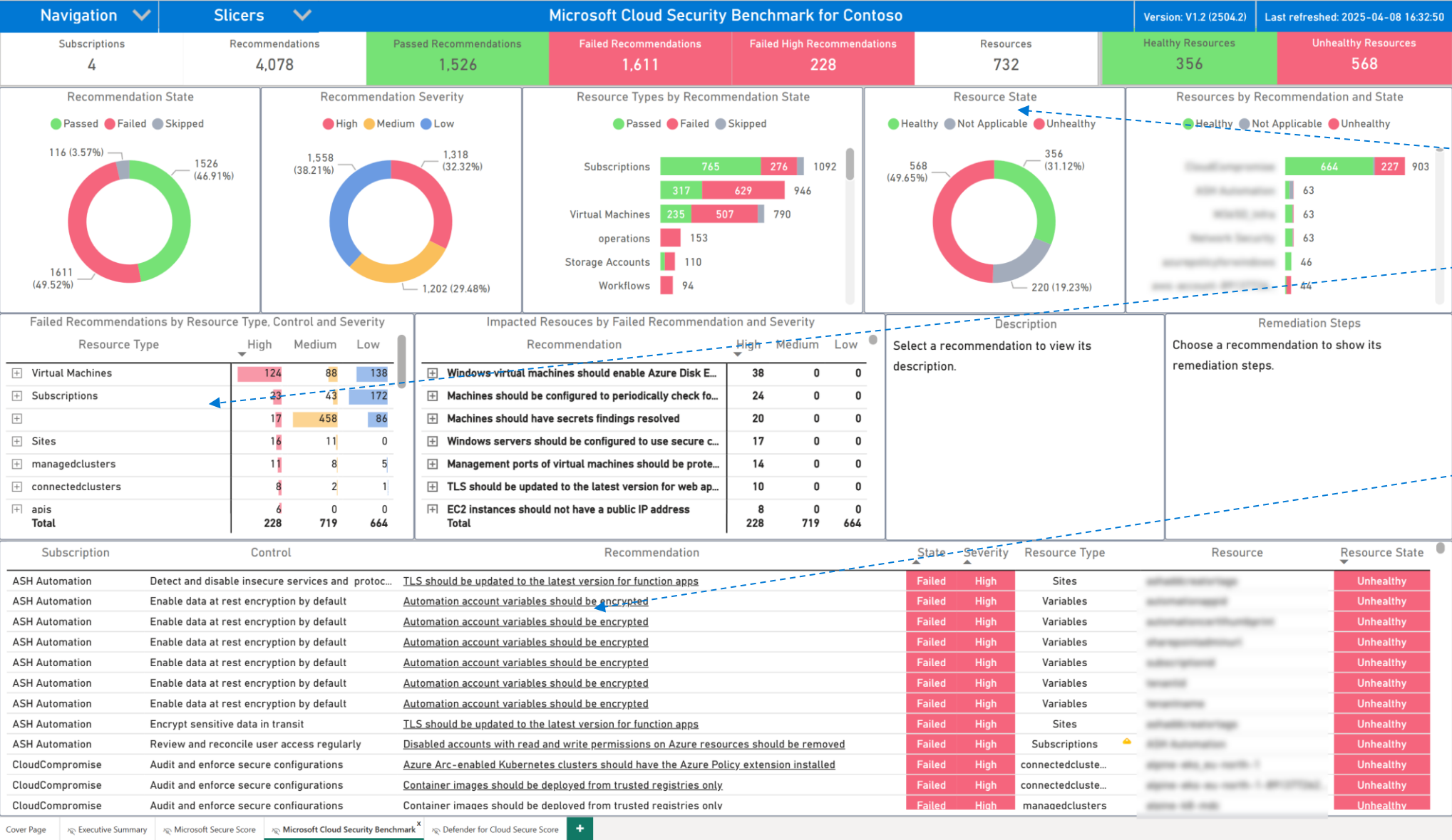
- Reverted security measures
- Changes in configuration
- Adverse user actions
- Device modifications

Interactive visuals that enable filtering by multiple categories

Recommendation details

- Implementation status
- Score
- ...

Power BI Dashboard – MCSB Example



Resources by state

- Healthy
- Unhealthy
- Not applicable

Interactive visuals that enable filtering by multiple categories

- Resource type
- Control
- Severity

Links to access filtered cloud resources directly with more details

Navigation

Slicers

Defender for Cloud Secure Score for Contoso

Version: V1.2 (2504.2)Last refreshed: 2025-04-08 16:32:50

Defender for Cloud Secure Score

55.34%

Subscriptions

4

Recommendations

2,350

Passed Recommendations

823

Failed Recommendations

1,045

Failed High Recommendations

333

Resources

570

Healthy Resources

206

Unhealthy Resources

485

Recommendations by Severity and State

Resources by State

Resource Types by State

Resources by Recommendation and State

Failed Recommendations by Resource Type, Control and Severity

Resource Type	High	Medium	Low
Virtual Machines	124	114	102
Deployments	98	0	0
managedclusters	42	18	5
apis	1	0	4
apis	1	0	0
Vaults	1	41	5
Sites	8	19	0
Total	333	295	417

Impacted Resources by Failed Recommendation and Severity

Recommendation	High	Medium	Low
Windows virtual machines should enable Azure Disk Enc...	38	0	0
Windows servers should be configured to use secure co...	17	0	0
Windows Defender Exploit Guard should be enabled on ...	0	17	0
Wildcards in roles should be removed in Azure Kuberne...	5	0	0
Web apps should request an SSL certificate for all incom...	0	5	0
Web Application should only be accessible over HTTPS	0	1	0
Vulnerabilities in security configuration on your Windows...	0	0	6
Total	333	295	417

Description

Select a recommendation to view its description.

Remediation Steps

Select a recommendation to view its remediation steps.

Subscription

Control

Recommendation

Severity

Resource Type

Resource

State

Last Status Change

ASH Automation

Encrypt data in transit

TLS should be updated to the latest version for function apps

High

Sites

...

Unhealthy

2025-01-15 18:37:31

ASH Automation

Implement security best practices

Automation account variables should be encrypted

High

Variables

...

Unhealthy

2025-01-15 18:37:31

ASH Automation

Implement security best practices

Automation account variables should be encrypted

High

Variables

...

Unhealthy

2025-01-15 18:37:31

ASH Automation

Implement security best practices

Automation account variables should be encrypted

High

Variables

...

Unhealthy

2025-01-15 18:37:31

ASH Automation

Implement security best practices

Automation account variables should be encrypted

High

Variables

...

Unhealthy

2025-01-15 18:37:31

ASH Automation

Implement security best practices

Automation account variables should be encrypted

High

Variables

...

Unhealthy

2025-01-15 18:37:31

ASH Automation

Implement security best practices

Automation account variables should be encrypted

High

Variables

...

Unhealthy

2025-01-15 18:37:31

ASH Automation

Implement security best practices

Key Vault secrets should have an expiration date

High

Vaults

...

Unhealthy

2025-03-19 07:12:56

ASH Automation

Manage access and permissions

Disabled accounts with read and write permissions on Azure resources should be remov...

High

Vaults

...

Unhealthy

2025-03-20 10:55:13

CloudCompromise

Access to secret objects should be restricted on Azure Kubernetes Services (AKS) cluste...

High

managedclusters

...

Unhealthy

2024-12-11 16:46:38

CloudCompromise

Access to secret objects should be restricted on Azure Kubernetes Services (AKS) cluste...

High

managedclusters

...

Unhealthy

2024-12-11 16:46:38

CloudCompromise

Access to secret objects should be restricted on Azure Kubernetes Services (AKS) cluste...

High

managedclusters

...

Unhealthy

2024-12-11 16:46:38

- Healthy
- Unhealthy
- Not applicable

- Resource type
- Control
- Severity

Links to access filtered cloud resources directly with more details

Power BI Dashboard – Microsoft Purview Recommendations



Scope

Data-Based Assessment	Our assessment is based entirely on the recommendations found in the provided .four files.
Enterprise Scope	This assessment is scoped to a single customer tenant, referred to as the enterprise.
Target Audience	This service is ideal for customers seeking full visibility into their security posture across the enterprise. For organizations with a very mature security setup, especially those using Defender for Cloud or other CSPM tools and practices, the added value may vary.
Remote Engagement	The results meeting will be conducted remotely, and all data analysis will be performed offline.
No Remediation	The scope of this assessment does not include remediation of any findings.





Outcomes

An enterprise security assessment is a comprehensive evaluation designed to identify and summarize security recommendations in an enterprise environment.



Provides detailed visuals via a Power BI dashboard, highlighting areas needing attention and enabling repeated use.



Delivers actionable recommendations, ensuring continuous improvement of the customer's security posture.



Provides a concise, executive-ready summary that highlights prioritized security recommendations, benchmarks your current enterprise security posture, and outlines a clear strategic path forward.

Requirements & Next Steps

Engagement Dates:	• Assessment files available to Microsoft: TBD • Two-hour assessment results meeting: TBD
Requirements:	• Windows machine to install Power BI Desktop or Power BI Service (web) • Read permissions on all subscriptions, Microsoft Defender XDR portal and Microsoft Purview are required to export the four required files.
Next Steps:	• Microsoft will share detailed instructions for data gathering with the customer. • Customer will provide the four exported files to Microsoft. • Microsoft will send out a Teams meeting invite for the two-hour assessment results meeting on the agreed date.



Thank you